Risk Assessment Process

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This document defines the methodology used by Stark Industries Inc. to identify, analyse, and evaluate information security risks. It ensures a consistent, repeatable, and effective approach to risk assessment in support of the Information Security Management System (ISMS).

Scope

This methodology applies to all information assets, personnel, systems, and operations within the scope of Stark Industries Inc.'s ISMS, specifically related to the development, deployment, and maintenance of the SaaS marketing platform.

Risk Assessment Process Overview

The risk assessment process consists of the following stages:

- Asset Identification
- Threat and Vulnerability Identification
- Risk Analysis (Likelihood × Impact)
- Risk Evaluation
- Risk Ownership Assignment
- Documentation of Results

Risk Assessment Criteria

- Likelihood rating:

Score	Description
1	Rare - May occur in exceptional circumstances
2	Unlikely - Not expected but possible
3	Possible - Might occur at some time

4	Likely - Expected to occur occasionally
5	Almost Certain - Expected to occur frequently

- Impact rating:

Score	Description
1	Negligible - No significant disruption or damage
2	Minor - Minor disruption or limited financial/reputational impact
3	Moderate - Noticeable impact requiring management attention
4	Major - Serious impact on operations, finances, or compliance
5	Severe - Critical impact, regulatory breach, or long-term damage

- Risk level calculation:
  - Risk Score = Likelihood × Impact
  - Maximum Score = 25

Risk Evaluation Criteria

Risk Score	Risk Level	Action Required
1–6	Low	Acceptable risk - monitor only
7–14	Medium	Treatment or mitigation required based on context
15–25	High	Unacceptable - immediate treatment required

Risk Acceptance Criteria

- **Low risks** are generally acceptable with monitoring.
- **Medium risks** require business justification or partial mitigation.
- **High risks** must be treated or explicitly accepted by senior management.

Asset Identification

Assets considered in risk assessments may include:

- Source code repository
- CI/CD Pipeline
- Cloud infrastructure (AWS EC2, S3)
- Employee laptops
- Data (even if no personal data is processed)

Threats and Vulnerabilities

Stark Industries Inc. uses recognised sources such as:

- OWASP Top 10
- NIST SP 800-30
- Industry threat intelligence
- Internal incident history

Each asset is assessed for applicable threats and vulnerabilities that could compromise confidentiality, integrity, or availability.

Risk Ownership

Every identified risk is assigned to a Risk Owner, typically the owner of the associated asset or business process. Risk Owners are responsible for validating assessments and supporting treatment efforts.

Review and Frequency

Risk assessments are:

- Reviewed at least **annually**
- Re-performed when there are significant changes to systems, processes, or threats
- Updated before management reviews and internal audits

Outputs and Records

- Risk Register
- Risk Assessment Report
- Updated Asset Inventory

- Treatment Plan input
- Statement of Applicability input